

Attachment H - CDRLS - Non-Technical DRDs

and

Requirements Statements List

National Aeronautics and Space Administration
Goddard Space Flight Center (GSFC)

Requirements Statements:

This requirements statements list consists of requirements that supplement the statement of work or performance work statement. These requirements are specific to agency-required procedures or protocols concerning matters related to contracts or other agreements; as a result, the following requirements are invoked by contract: TBD.

1. IT Purchase Authorization

- a. The contractor shall ensure all IT products and services direct charged to the contract are approved through the OCIO's Commercial IT Request (CITR) Application. This includes, but is not limited to, FITARA, Supply Chain Risk Management (SCRM), IPv6, and 508 compliance. No purchases of commercial IT products or services should be made prior to coordination and approval by the OCIO. Contractor shall report purchases monthly utilizing DRD 2a, CITAR.
- b. This contract shall only be used to purchase software, software maintenance, hardware, or hardware maintenance necessary for the performance of this contract. NASA shall own the license(s) or subscriptions for any software or applications purchased. All hardware shall be titled to NASA.

2. Section 508 Conformance

- a. The contractor shall ensure that all products, platforms, services, and communications delivered as part of this work statement that are Information and Communication Technology (ICT) or contain ICT, conform to the Revised Section 508 of the Rehabilitation Act Standards, 36 C.F.R. § 1194.1 & Apps. A, C & D. The Standards may be found at <https://www.access-board.gov/ict/>.

3. Records Management

- a. The Contractor shall maintain all records created for Government use or created in the course of performing the contract and/or delivered to, or under the legal control of the Government and must be managed in

accordance with Federal law, including but not limited to, the Federal Records Act (44 U.S.C. chs. 21, 29, 31, 33), NARA regulations at 36 CFR Chapter XII Subchapter B, as well as NASA records policies (NPD 1440.6, NASA Records Management Program, and NPR 1441.1, NASA Records Management Program Requirements).

- b. The Contractor shall ensure that NASA-owned/Contractor-held records are segregated from contractor-owned records and from non-record materials and report holdings of NASA records.
- c. The Contractor shall immediately notify the Contracting Officer and NASA Records Officer upon discovery of any inadvertent or unauthorized removal, defacing, alteration, or destruction of Federal records. Destruction of Federal Records is EXPRESSLY PROHIBITED unless in accordance with records retention schedules or as directed by the Contracting Officer.
- d. All Contractor employees assigned to this contract who create, work with, or otherwise handle Federal Records are required to complete mandatory NASA- provided records management training. The Contractor shall ensure that training has been completed according to agency policies, including initial training and any required annual or refresher training.
- e. The Contractor shall incorporate the substance of this clause, its terms and requirements including this paragraph, in all subcontracts under this contract, and require written subcontractor acknowledgment of same.

4. Use of Artificial Intelligence (AI) During Contract Performance

- a. The contractor must disclose any potential or intended use of Artificial Intelligence (AI) technologies, tools, or systems in the performance of this contract. If it is unknown at the time of contract award whether AI will be used, the contractor must provide written notice to the Government prior to the deployment of any AI systems during contract performance. If AI technologies are introduced after the commencement of contract performance, the contractor must notify the contracting officer in writing prior to the release or deployment of any AI component, capability, or system in the NASA environment.
- b. The Government reserves the right to review, approve, or disapprove the proposed use of AI technology in the performance of this contract. The contractor must obtain written approval from the contracting office before implementing AI systems.
- c. If any subcontractor intends to use AI technologies in the performance of work under this contract, the contractor must ensure that similar notification and disclosure requirements apply to all subcontractors. The contractor is responsible for collecting the notification

and disclosure requirements from subcontractors and submitting them to the Government.

Non-Technical Data Requirements Deliverables (DRDs):

1. Capital Planning and Investment Control (CPIC) Cost Reporting DRD and associated template.

It is the Government's responsibility to complete annual CPIC reporting. Each organization shall report IT spend to their cognizant Investment Manager in accordance with annual Agency reporting guidance. This DRD will assist the Government in collecting this information from the contractor. The DRD is not mandatory but is recommended to facilitate the reporting that is required.

2. Commercial IT Authorization Report (CITAR) DRD and associated template.

This DRD is a report of completed commercial IT purchases authorized through the CITR application. Submission is not required when there are no purchases to report.

3. Security Requirements for Unclassified IT Resources DRD.

This DRD represents a baseline set of requirements for all contracts. Acquisition teams may add additional requirements to this DRD, or make requirements more stringent, but may not delete any of the requirements in the baseline DRD without coordinating with the RCA Team. Certain sections of this DRD may not be applicable to a particular contract based on requirements (e.g., requirements for a System Security Plan).

This DRD requires a Cyber Supply Chain Risk Management (C-SCRM) Plan consistent with the recommended template in NIST SP 800-161. This document may be found at:

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-161.pdf>.

Section 3.1 provides a summary of ICT SCRM controls and references additional guidance in Appendix E, "ICT SCRM Plan Template." (ICT = Information and Communications Technology)

This DRD has an attachment, "NASA C-SCRM Questionnaire." This questionnaire aligns with the above referenced NIST template and is intended to make fulfilling this requirement easier. At this time, the OCIO's questionnaire is optional. The OCIO will accept either a plan that complies with NIST SP 800-161 or this template. Contractors DO NOT need to submit both a plan and this template. If a contractor has an existing C-SCRM plan that complies with NIST SP 800-161, there is no requirement for the contractor to complete the OCIO's questionnaire.

4. Commercial Artificial Intelligence Risk and Impact Assessment (CAIRIA) DRD

Note: This DRD must be included in all solicitations and contracts. Submission is required when the contractor will acquire or use covered AI in performance of the contract.

1. DRD Title: Security Requirements for Unclassified IT Resources		
2. DRD No.: 1a	3. Data Type: 1	4. OPR: OCIO
5. Solicitation No.: 80GSFC26R0011		6. Contract No.: TBD
7. Date Issued: 03/23/2026	8. Date Revised: N/A	9. DRD Category: Technical ☒ Administrative ☐ S&MA ☐
10. Description/Use: To ensure that IT security requirements, including training, and Cyber Supply Chain Risk Management (C-SCRM), are met during performance of this contract.		
11. Distribution: All deliverables required by this DRD, except for the C-SCRM plan, shall be submitted electronically to the CO, COR, and NASA Organization's Information System Security Officer (ISSO) (i.e., Security Officer). Approval will be provided by the ISSO. If the organization does not have an ISSO, approval will be provided by the NASA Information Owner. C-SCRM plans shall be submitted to and approved by the ICT/C-SCRM Service Element Lead at agency-dl-ocio-cys-cp-scrm@mail.nasa.gov. Initial Submission: Information System Security and C-SCRM Plan(s): For contractor-owned systems, due at the start of phase-in. Initial submission not required for existing, approved plans for Government-owned and Contractor-managed systems. For new Federal Information Systems, due with the delivery of the system. Non-Federal System Certification: Prior to any transfer of NASA non-public information to the contractor, the contractor shall provide documentation of the certification of the non-federal system to the security officer of the NASA organization that owns the information (typically the organization responsible for the contract). If the organization does not have an ISSO, the attestation shall be provided to the NASA Information Owner. Information on Employees in Sensitive Positions/Assignments Report: At the start of phase-in IT Security Point of Contact: At the start of phase-in IT Security Awareness Training: Training required prior to access to NASA information and systems. IT Security Role Based Training: Foundational training is provided prior to performance of assigned role. Initial evidence showing completion due at the end of phase-in. Submission Frequency: Information System Security Plan(s) and C-SCRM Plan: As Required Non-Federal System Certification: Annually Information on Employees in Sensitive Positions/Assignments Report: Annually IT Security Point of Contact: As Required IT Security Awareness Training: Annual on anniversary date of initial training		

1. DRD Title: Commercial IT Authorization Report		
2. DRD No.: <u>2a</u>	3. Data Type: 1	4. OPR: OCIO
5. Solicitation No.: <u>80GSFC26R0011</u>		6. Contract No.: <i>TBD</i>
7. Date Issued: 12/01/2023	8. Date Revised: N/A	9. DRD Category: Technical ☐ Administrative ☒ S&MA ☐
10. Description/Use: The purpose of this DRD is to document and report, in accordance with OCIO policy, purchases authorized through the OCIO Commercial IT Request (CITR) Application.		
11. Distribution: Electronic Submission to the CO and COR Initial Submission: Within 90 days of contract start Submission Frequency: Monthly on the 15 th of each month or the next business day. Final Submission at end of contract for contract closeout. Format: Contractor shall use the CITAR Template. Contractor may not alter the template. Each report shall be cumulative from contract start. Interrelationship: <u>PWS Section 1.2.1.1</u> , IT Purchase Authorization Applicable Documents: OMB Memorandum M-15-14, Management and Oversight of Federal Information Technology. OMB Memorandum M-16-02, Category Management Policy 15-1: Improving the Acquisition and Management of Common Information Technology: Laptops and Desktops. OMB Memorandum M-16-12, Category Management Policy 16-1: Improving the Acquisition and Management of Common Information Technology: Software Licensing. OMB Memorandum M-16-20, Category Management Policy 16-3: Improving the Acquisition and Management of Common Information Technology: Mobile Devices and Services. Scope: Complete the CITAR Template Contents: See CITAR Template Remarks: See “Instructions” Tab on the CITAR Report Template. Negative responses are not required. Maintenance: N/A		

IT Security Role Based Training: Annual on anniversary date of initial training. Evidence of completion due annually.

Format: Unless otherwise directed, the data requested in this DRD shall be delivered to the Government in soft-copy via an electronic transfer mechanism (e.g., electronic mail, flash drive, or file transfer protocol) in a format readable by a Government device utilizing the standards in NASA-STD-2804, “Minimum Interoperability Software Suite.”

Interrelationship: PWS Section 1.2

Applicable Documents: Most current versions of the following:

FAR 52.240-91, Security Prohibitions and Exclusions

FAR 52.240-93, Basic Safeguarding of Covered Contractor Information Systems

FISMA 2014, Federal Information Security Modernization Act 2014

NFS 1852.240-76, Security Requirements for Unclassified IT Resources

NFS 1852.223-75, Major Breach of Safety or Security

NFS 1852.237-72, Access to Sensitive Information

NFS 1852.237-73, Release of Sensitive Information

NIST SP 800-171, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations

NIST SP 800-53, Security and Privacy Controls for Information Systems and Organizations

NIST SP 800-161, Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations

NPR 1382.1, NASA Privacy Procedural Requirements

NPD 2810.1, Information Security Policy

NPR 2810.1, Security of Information and Information Systems

NPR 2810.7, Controlled Unclassified Information

NPR 7120.7, NASA Information Technology Program and Project Management Requirements

OMB Circular A-130, Management of Federal Information Resources

Scope: All contracts that purchase, lease, network to, or otherwise utilize covered articles, which includes Government-funded IT (as defined by the [FAR](#)) must comply with NASA IT Security and C-SCRM Requirements.

Contents: The Federal Information Security Modernization Act (FISMA) and Executive Branch policy require external providers that process, store, or transmit federal information or operate information systems on behalf of the federal government to meet the same security and privacy requirements as federal agencies.

Information System Security Plan (i.e., System Security Plan, IT Security Plan, or Security Plan):

When the contractor is operating a Federal Information System (FIS) on behalf of NASA or is providing a FIS in the execution of this contract, that system must have an Information System Security Plan in accordance with NIST Special Publication (SP) 800-53, “Security and Privacy Controls for Information Systems and Organizations” at the revision number required at the issuance of the contract. This plan and supporting documents shall be entered into the NASA cybersecurity system of record pursuant to Authorization to Operate (ATO) requirements set forth in NASA Policy Directive 2810.1, “NASA Information Security Policy” and NASA Procedural Requirement (NPR) 2810.1, “Security of Information and Information Systems.” The FIS security plan and ATO must be in place before any system may operate in the NASA environment.

NON-FEDERAL SYSTEM SECURITY CERTIFICATION

When the contractor will receive, process, store or transmit NASA non-public information, especially Controlled Unclassified Information (CUI) including Personally Identifiable Information (PII) on a non-federal system (e.g., the

contractor's corporate system) the system must meet the requirements for data protections detailed in NIST Special Publication 800-171, "Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations."

This documentation may take the form of:

- a. A third-party review/audit certifying that the non-federal system meets the requirements of NIST SP 800-171 or equivalent standard of information protection, such as the ISO 27001 standard, for example.
- b. A certification from another federal agency such as the DOD Cybersecurity Maturity Model Certification (CMMC) Level 2.

INCIDENT NOTIFICATION

The contractor shall report immediately upon notification any incident involving NASA information on nonfederal (contractor) systems to SOC@nasa.gov.

IT SECURITY POINT OF CONTACT:

The contractor shall identify a point of contact that NASA may reach in its attempt to address IT and cybersecurity issues. The point of contact shall have the authority to ensure the immediate notification of the NASA Security Operations Center of any incident involving NASA information.

IT SECURITY AWARENESS TRAINING:

Contractor employees subject to this contract, defined as those requiring physical access to NASA facilities or electronic access to NASA systems, shall complete the NASA approved IT Security Awareness Training annually. NASA Cybersecurity and Privacy Awareness training is available through the SATERN online system and must be completed prior to access to NASA information and systems. Completion of the training is tracked automatically by NASA and must recur each year by the anniversary of the initial training as a condition of continued access. Cybersecurity and Privacy training is updated throughout the year as needed, so there is no defined training period.

CYBERSECURITY AND PRIVACY ROLE BASED TRAINING:

Contractor employees subject to this contract shall complete NASA's Cybersecurity and Privacy Role-Based Security Training in SATERN related to the following role-based functions prior to performing the role:

- Information System Owner (ISO)
- Information Systems Security Officer (ISSO)
- Information System Security Engineer (ISSE)

NAMS access to these roles in the Risk Information Security Compliance System (RISCS) will be restricted to those that have completed the role-based training within a year of the previous training. Only the training specified in SATERN will be valid for the purpose of fulfilling the training requirement and those who do not take the training annually may be suspended from RISCS access.

INFORMATION ON EMPLOYEES IN SENSITIVE POSITION(S)/ASSIGNMENTS REPORT:

The Information on Employees is Sensitive. IT Security (ITS) Positions/Assignments Report shall provide information annually for personnel screening as required by NPR 2810.1(series), and NPR 1600.1 on position risk.

CYBER SUPPLY CHAIN RISK MANAGEMENT (C-SCRM) PLAN:

NIST defines C-SCRM as a systematic process for managing exposure to cybersecurity risks throughout the supply chain and developing appropriate response strategies, policies, process, and procedures. A C-SCRM plan addressing

contractor systems that will be used in performance of the contract, shall be delivered prior to the processing, transmission, or storage of non-public NASA information on these contractor systems. The C-SCRM plan shall be consistent with the template in NIST SP 800-161, "ICT SCRM Plan Template," or the attached, optional questionnaire.

Remarks: None

Maintenance:

Information System Security Plan(s) shall be kept up to date as changes to the baseline configuration of the system(s) occur.

Non-Federal System Certifications shall be maintained annually or per the certifying body's standard.

Information on Employees in Sensitive Positions/Assignments Report shall be maintained annually.

It Security Point of Contact shall be kept up to date as changes occur.

Completion of Cybersecurity and Privacy Role Based Training is due annually in SATERN and will be tracked by NASA.

C-SCRM plans shall be kept up to date as changes occur to organizational C-SCRM processes, policies, and procedures, and/or, new components are introduced.

1. DRD Title Information Technology (IT) Capital Planning and Investment Control (CPIC)		
2. DRD No.: <u>3a</u>	3. Data Type: 2	4. OPR: OCIO
5. Solicitation No.: <u>80GSFC26R0011</u>		6. Contract No.: <i>TBD</i>
7. Date Issued: 2/8/2024	8. Date Revised: N/A	9. DRD Category: Technical ☐ Administrative ☒ S&MA ☐
10. Description/Use: To document the Contractor's compliance with Federal and NASA IT CPIC Planning and Reporting regulations and reporting requirements.		
11. Distribution: Electronic Submission to the CO, COR, Customer Organization Investment Manager		
Initial Submission: With the first CPIC reporting cycle after contract award. The Center Investment Manager (CIM) will provide the annual CPIC reporting schedule based on Office of Management and Budget (OMB) direction. Submission Frequency: As required by Government, but at a minimum once annually to support Government budget formulation and IT reporting activities. The date may vary by Center and organization, but typically will occur in late January/early February so that the data is available to support budget formulation activities and data collection for CPIC reporting requirements. The CIM will provide the annual CPIC reporting schedule based on OMB direction. Format: Unless otherwise directed, the data requested in this DRD shall be delivered to the Government in soft-copy via an electronic transfer mechanism (e.g., electronic mail, flash drive, or file transfer protocol) in a format readable by a Government device utilizing the standards in NASA-STD-2804, Minimum Interoperability Software Suite. Interrelationship: <u>PWS Section 1.1.7</u> Applicable Documents: OMB Circular A-11 and A-130 Scope: Information Technology (as defined in the Clinger-Cohen Act) is subject to certain scrutiny and reporting requirements as set forth in Legislative actions, and Executive and Agency mandates and directives. The passing of the Federal Information Technology Reform Act (FITARA) of 2014 expanded on Clinger Cohen and the requirements for agencies to assess and report their information technology (IT) investment portfolios. The Office of Management and Budget (OMB) Circular A-130 establishes the policies that govern Federal IT in order to implement statutory IT requirements, and includes IT Investment management, planning, and control (i.e., CPIC). The annual OMB Circular A-11 establishes the guidelines and requirements for IT investment reporting to the Executive Branch and Congress as part of the annual Federal budget cycle. The Contractor shall prepare a report of all IT expenditures consistent with the Agency's guidelines and policies regarding the management and reporting of IT resources, to include the annual CPIC data in support of the agency's budget formulation process. Any additional reporting requirements associated with CPIC reporting and data collection process will be covered by this DRD. In conformance with IT management and reporting processes, to include CPIC, Contractors shall participate in data		

collection and reporting efforts. Contractors shall furnish the data needed for the Agency to comply with statutory and OMB requirements including but not limited to those documented in OMB Circular A-11. Accurate and complete data submissions are to be made in a manner consistent with the reporting structure, and within the timeframes established for the Center.

The contractor may reach out to the CIM for questions regarding CPIC reporting.

Contents: All Contractors shall submit their Fiscal Year spending plans for review and approval to the cognizant Center Chief Information Officer (CIO), or designee, prior to the beginning of the Fiscal Year (October). Changes to spending plans during the Fiscal Year shall be approved by the CIO, or designee, before implementation. Formats and reporting processes and procedures will be provided annually based upon Center and Agency requirements.

Examples of documentation, formats, processes, procedures, and structures will be provided annually in support of the data call. The attached Excel Spreadsheet, entitled “CPIC DRD Template for IT Portfolio PPM Data Collection,” is a sample template for Year 1 of the Contract. This is a dynamic process, and formats, processes, procedures, and structures are subject to change. The reporting requirement is defined by OMB annually. Each year, OMB may request varying levels of reporting across varying levels of technologies and labor, depending on their focus.

Remarks: None

Maintenance: Updated with Annual Submission

1. DRD Title: Commercial Artificial Intelligence Risk and Impact Assessment (CAIRIA)		
2. DRD No.: <u>4a</u>	3. Data Type: 1	4. OPR: OCIO
5. Solicitation No.: 80GSFC26R0011		6. Contract No.: <i>TBD</i>
7. Date Issued: 09/30/2025	8. Date Revised: N/A	9. DRD Category: Technical ☒ Administrative ☐ S&MA ☐
10. Description/Use: To ensure that requirements for Artificial Intelligence (AI) impact and risk assessments are met for all AI systems utilized during work associated with this contract.		
11. Distribution: All deliverables required by this DRD shall be submitted electronically to the CO, COR, and NASA's Chief Artificial Intelligence Officer (CAIO) at agency-caio@mail.nasa.gov . Approval will be provided by the CAIO. Initial Submission: Contract Phase-In and/or Prior to Use of new AI components or capabilities to perform contract performance Submission Frequency: Updated annually after initial submission and when new AI components or capabilities are introduced. Format: Unless otherwise directed, the data requested in this DRD shall be delivered to the Government in soft-copy via an electronic transfer mechanism (e.g., electronic mail, flash drive, or file transfer protocol) in a format readable by a Government device utilizing the standards in NASA-STD-2804, "Minimum Interoperability Software Suite." Interrelationship: <u>PWS Section 1.2.4,</u> Applicable Documents: Executive Order 13960, Promoting the Use of Trustworthy Artificial Intelligence in the Federal Government Executive Order 14179, Removing Barriers to American Leadership in Artificial Intelligence OMB Memorandum M-15-14, Management and Oversight of Federal Information Technology. OMB Memorandum M-25-21, Accelerating Federal use of AI through Innovation, Governance, and Public Trust. OMB Memorandum M-25-22, Driving Efficient Acquisition of Artificial Intelligence in Government. Scope: AI is defined as Artificial Intelligence is defined in Section 238(g) of the John S. McCain National Defense Authorization Act for Fiscal Year 2019. “(g) ARTIFICIAL INTELLIGENCE DEFINED. —In this section, the term “artificial intelligence” includes the following: (1) Any artificial system that performs tasks under varying and unpredictable circumstances without significant human oversight, or that can learn from experience and improve performance when exposed to data sets. (2) An artificial system developed in computer software, physical hardware, or other context that solves tasks		

- requiring human-like perception, cognition, planning, learning, communication, or physical action.
- (3) An artificial system designed to think or act like a human, including cognitive architectures and neural networks.
- (4) A set of techniques, including machine learning, that is designed to approximate a cognitive task.
- (5) An artificial system designed to act rationally, including an intelligent software agent or embodied robot that achieves goals using perception, planning, reasoning, learning, communicating, decision making, and acting.”

OMB Memorandum M-25-21 provides this additional technical context:

1. This definition of AI encompasses, but is not limited to, the AI technical subfields of machine learning (including deep learning as well as supervised, unsupervised, and semi-supervised approaches), reinforcement learning, transfer learning, and generative AI.
2. This definition of AI does not include robotic process automation or other systems whose behavior is defined only by human-defined rules or that learn solely by repeating an observed practice exactly as it was conducted.
3. For this definition, no system should be considered too simple to qualify as covered AI due to a lack of technical complexity (e.g., the smaller number of parameters in a model, the type of model, or the amount of data used for training purposes).
4. This definition includes systems that are fully autonomous, partially autonomous, and not autonomous, and it includes systems that operate both with and without human oversight.

AI Systems include the following capabilities:

CLASSIFICATION	DESCRIPTION	EXAMPLES
Generative AI	AI that generates new or synthetic content (e.g., images, videos, audio, text, code).	Chatbots, image generation, code completion, synthetic media, data augmentation, retrieval-augmented generation (RAG), deep research
Agentic AI	AI systems that perform tasks or make decisions autonomously with minimal human intervention.	Task automation, personal assistants
Classical/Predictive Machine Learning	Models trained on data to make predictions or classifications based on identified patterns or relationships.	Sales forecasting, weather forecasting, spam detection, recommendation systems, credit/fraud scoring, anomaly detection
Computer Vision	AI that processes and interprets visual data (e.g., images and videos).	Object detection, facial recognition, biometric identification, medical imaging, image segmentation
Natural Language Processing (NLP)	AI that processes, interprets, and shares information in human language.	Sentiment analysis, speech-to-text, text-to-speech
Reinforcement Learning	AI trained through trial and error using rewards and penalties to optimize decision-making policies.	Robotics operating in physical environments, strategic game play, autonomous systems (drones)

Contents:

Baseline and High-Impact AI Risk and Impact Assessments are included below. Formats and reporting processes and procedures will be provided annually by the CAIO based upon OMB and Agency requirements. This is a dynamic process, and formats, processes, procedures, and structures are subject to change.

Definitions

Baseline AI: Any AI product, tool, software, service, or system that does not meet the definition of “high-impact AI” is considered a **Baseline AI** system.

High-Impact AI: A system is considered **high-impact AI** if it meets the criteria in OMB M-25-21 section 4(a), which states that high-impact AI is any AI model or system with an output that serves as a principal basis for decisions or actions with legal, material, binding, or significant effect on:

1. an individual or entity's civil rights, civil liberties, or privacy; or
2. an individual or entity's access to education, housing, insurance, credit, employment, and other programs;
3. an individual or entity's access to critical government resources or services;
4. human health and safety;
5. critical infrastructure or public safety; or
6. strategic assets or resources, including high-value property and information marked as sensitive or classified by the Federal Government.

For the purposes of AI development and deployment at NASA, this includes AI systems that:

1. Perform or significantly support government decisions affecting rights, safety, benefits, entitlements, or protections
2. Pose significant risks of harm to individuals, groups, or public trust
3. Operate with a high level of autonomy or limited human oversight
4. Are used in safety-critical or mission-critical systems

Baseline AI Risk and Impact Assessment:

For any AI product, tool, software, service, or system considered as a baseline AI system, the contractor shall provide, at a minimum, plain-language documentation of the following elements:

1. The AI system's function and role.
2. Any automated decision-making involved.
3. All data sources and types used to develop or operate the system.
4. Characterization of model type, autonomy level, and model update mechanisms (e.g., clustering, reinforcement learning, deep neural networks, large language models, computer vision models, time-series forecasting models, recommendation systems). Also include the AI Classification from the table included above.
5. Known risks or limitations (e.g., performance boundaries, error rates, fairness or bias concerns, data quality limitations, explainability challenges, adversarial vulnerabilities, model drift, hallucination risks).
6. Human review or override mechanisms, if applicable.
7. Information on open-source or third-party models or datasets including data shared with or received from external systems or models.
8. Process for testing, validation, and performance monitoring procedures, including:
 - Key performance measures or acceptance criteria
 - Security and robustness testing (e.g., red-teaming, adversarial input resistance)
 - Whether testing is manual, automated, or third-party validated
 - Ongoing monitoring or alerting for degradation or unexpected behavior

High-Impact AI Risk and Impact Assessment:

For high-impact AI systems, the contractor shall provide, **in addition to the Baseline AI Risk and Impact Assessment**, plain-language documentation of the following elements:

1. Assessment of potential impacts on individuals' rights, safety, access to government services, or well-being.
2. Identification of all known or reasonably foreseeable risks **and the contractor's corresponding mitigation strategies**, including safeguards, operational controls, monitoring mechanisms, and corrective action procedures.
3. Process for testing, validation, and performance monitoring procedures, including:
 - a. Defined performance measures and system acceptance criteria.
 - b. Security and robustness testing (e.g., red-teaming, adversarial input resistance).
 - c. Identification of whether testing is manual, automated, or third-party validated.
 - d. Ongoing monitoring procedures and alerting for system degradation or unexpected behavior.
 - e. Iterative fairness and bias audits, including evaluation across affected populations.
 - f. Description of the testing objectives and the operational scope covered.
 - g. Conditions that trigger model re-testing or re-validation during the system lifecycle.
 - h. Methods used to document test results, failures, and corrective actions.
 - i. Evidence of independent review, validation, or audit readiness where applicable.
 - j. Approach to versioning and traceability of testing and model changes.
4. Transparency and user notice plans, including intended disclosures and user-facing explanations (if applicable).

Upon the Government's request, the contractor must provide any additional information to support internal AI risk tracking and lifecycle management. If the AI system's use, function, or impact materially changes during performance, the contractor may be required to support reassessment, including possible reclassification as a high-impact AI system.

Remarks: None.

Maintenance: CAIRIA plans shall updated annually, or as new AI components or capabilities are introduced.